

Technical issues and target architecture

This document tells you **what is wrong**, **how the folders must look**, and **how to fix the code**. Split the project into three apps: Website frontend, Admin frontend, and Backend. Do not rewrite the auth model that already works.

3 apps

website-frontend · admin-frontend · backend

22 issues

structure first, then code defects

English

follow tasks in order · keep JWT rotation

Read this before you change a file

Do

1. Fix folder structure first (three apps). Mixing marketing pages and admin in one Next.js tree is the root problem.
2. Then fix the defects listed per app. One task = one focused change.
3. Keep refresh-token rotation, bcrypt 12, httpOnly cookie, generic login errors.
4. Work inside the inner folder: `serendib-wild-trails-main/` (the zip is nested).

Do not

- Do not add Packages / Settings / Enquiries modules until the three-app split is done.
- Do not paste `http://localhost:5000` into new files. Use env vars.
- Do not put a JWT in localStorage.
- Do not invent Google reviews or extra WhatsApp numbers.

What you already did well: refresh token rotation + SHA-256 hash, password hashing, cookie path `/api/auth`, CORS with credentials, Mongoose enums, `generateStaticParams`, labelled form fields. Keep those. Harden around them.

Work order

1. **Architecture** — flatten the zip, create `website-frontend`, `admin-frontend`, `backend`.
2. **Move code** — marketing site vs admin vs API, no shared Redux on public pages.
3. **Fix defects** — images, env URLs, validation, rate limit, duplicated content, fake admin UI.

Three apps, not one mixed Next.js tree

Today the public safari website and the admin dashboard live in the **same** Next.js app (app/page.tsx next to app/admin/...). Redux session restore therefore runs on the homepage. Admin CSS, marketing CSS, and API calls are tangled. That is not how this product should be built.

Current (wrong): one Next.js project contains Website + Admin. Backend is only a sibling folder. Content arrays are copy-pasted. public/images/ is missing.

Target repository

```
serendib-wild-trails/
├── README.md
├── .gitignore
├── website-frontend/      ← public marketing site (Next.js)
│   ├── app/
│   │   ├── layout.tsx
│   │   ├── page.tsx
│   │   ├── booking/page.tsx
│   │   ├── safaris/page.tsx
│   │   ├── safaris/[slug]/page.tsx
│   │   ├── destinations/[slug]/page.tsx
│   │   └── components/    ← Navbar, Hero, Footer, sections
│   ├── lib/
│   │   ├── site.ts        ← phones, WhatsApp, brand
│   │   ├── api.ts         ← NEXT_PUBLIC_API_URL
│   │   └── content/
│   │       ├── safaris.ts
│   │       └── destinations.ts
│   ├── public/images/
│   ├── .env.example
│   └── package.json
├── admin-frontend/        ← staff dashboard only (Next.js)
│   ├── app/
│   │   ├── layout.tsx     ← sidebar + auth gate
│   │   ├── login/page.tsx
│   │   ├── dashboard/page.tsx
│   │   └── bookings/page.tsx
│   ├── store/             ← Redux lives HERE only
│   ├── lib/api.ts         ← refresh-token mutex
│   ├── .env.example
│   └── package.json
└── backend/              ← Express API (already exists)
    ├── server.js
    ├── config/db.js
    ├── routes/
    ├── controllers/
    ├── models/
    ├── middleware/
    ├── validators/        ← add this
    ├── scripts/seedAdmin.js
    ├── .env.example       ← add this
    └── package.json
```

What each app is allowed to contain

Website frontend

CUSTOMER-FACING

- Home, safaris, destinations, gallery, booking form
- No Redux, no admin session restore
- May POST /api/bookings only
- No Bearer token, no /admin routes

Admin frontend

STAFF-FACING

- Login, dashboard, booking list
- Redux auth + httpOnly refresh cookie
- Calls protected booking APIs
- No marketing Navbar, no WhatsApp CTAs

Backend

SOURCE OF TRUTH

- Auth + bookings REST API
- MongoDB models
- Validation, rate limit, indexes
- No React, no CSS, no pages

How to split (steps)

1. Flatten the nested zip so the repo root is the real project.
2. Rename current Next app folder thinking: it is *both* website and admin. Create `website-frontend/` and `admin-frontend/` as two Next.js apps (copy `package.json` / `tsconfig` / `next.config`, then delete what each app does not need).
3. Move `app/page.tsx`, `app/safaris`, `app/destinations`, `app/booking`, `app/components` into `website-frontend`. Remove `app/admin` and `store/` from it.
4. Move `app/admin/*` and `store/` into `admin-frontend`. Routes become `/login`, `/dashboard`, `/bookings` (no need for `/admin` prefix inside an admin-only app).
5. Leave `backend/` where it is. Add `validators/` and `.env.example`.
6. Website `.env`: `NEXT_PUBLIC_API_URL=http://localhost:5000`. Admin same. Backend: Mongo + JWT secrets + `FRONTEND_URL` (allow both `localhost:3000` and admin port, e.g. `3001`).
7. CORS must allow **both** frontend origins (website and admin), not only one URL.

Dev ports: website 3000, admin 3001 (`next dev -p 3001`), backend 5000. Update backend CORS to an array: `["http://localhost:3000", "http://localhost:3001"]`.

Defect register (fix these after the split)

ID	Sev	App	Issue
S1	P0	Repo	Zip nested twice. Flatten before anything else.
S2	P0	Repo	Website and Admin share one Next.js tree. Split into three apps.
S3	P0	Website	<code>public/images/</code> missing. Every hero/logo/gallery path is broken.
S4	P0	Both FEs	API host hardcoded <code>http://localhost:5000</code> in 4 files.
S5	P0	Website	Metadata still "Create Next App". package name <code>ceylon-safari</code> . README is the Next scaffold.
C1	P1	Backend	No rate limit on login or public booking POST.
C2	P1	Backend	Booking body only checks "field exists". Past dates, guestCount 999, bad emails reach Mongo.
C3	P1	Backend	Admin search uses raw <code>\$regex: search</code> (unsafe / slow).
C4	P1	Backend	JWT secrets never checked at boot. Missing env → vague runtime failure.
C5	P1	Backend	CORS is a single origin. After split you need website + admin.
C6	P1	Website	Safari/destination copy duplicated in 3 files. Habarana page exists, homepage grid omits it.
C7	P1	Website	Three WhatsApp numbers. Home "View Route Details" opens WA on a third unused number, not the slug page.
C8	P1	Admin	Dashboard is a mock: dead nav (#), fake 0 stats, hardcoded "No bookings yet".
C9	P1	Admin	Redux restore runs on public pages today. After split it must run only in admin-frontend.
C10	P1	Website	Geist loaded but not applied. <code>prefers-color-scheme: dark</code> inverts the cream brand.
C11	P2	Admin	401 refresh duplicated (dashboard vs bookings) with no mutex — token rotation can kick the user out.
C12	P2	Admin	<code>logoutAdmin.rejected</code> keeps <code>isAuthenticated</code> <code>true</code> .
C13	P2	Backend	No 4-arg error middleware. 404 handler is last. No booking indexes.
C14	P2	Website	Hero claims "Google reviews"; testimonials are invented names.
C15	P2	Repo	Zero tests. Backend <code>npm test</code> exits 1. No <code>.env.example</code> .
C16	P2	Backend	<code>package.json</code> main is <code>index.js</code> but entry is <code>server.js</code> .
C17	P2	Both FEs	Broken indentation, mixed Tailwind + CSS modules, leftover Next SVGs / AGENTS.md.

Public site defects and how to fix them

W1

P0 · Assets

Add the missing image set

Code references `/images/safari-logo-transparent.png`, `park webps`, and `/images/safaris/*-1.webp ... -6.webp`. `public/` only has the five create-next-app SVGs.

```
website-frontend/public/images/
```

Done when: Home, safari list, destination detail, booking page show real photos. No broken-image icons.

W2

P0 · Config

One API helper, env-based URL

```
website-frontend/lib/api.ts .env.example
```

```
const API_BASE = process.env.NEXT_PUBLIC_API_URL ?? "http://localhost:5000";
export const apiUrl = (path) => `${API_BASE}${path}`;
```

Booking page currently fetches `http://localhost:5000/api/bookings` inline. After the split, that is the *only* website API call — keep it in `lib/api.ts`.

Done when: `grep` finds no raw `localhost:5000` in `app/`.

W3

P0 · Brand

Replace Create Next App leftovers

```
app/layout.tsx package.json root README.md
```

```
title: "Serendib Wild Trails | Safaris from Habarana"
description: "Private jeep safaris, village tours and cultural journeys in Sri Lanka."
```

Rename package from `ceylon-safari` to `serendib-website`. `README` must start both frontends and the backend, plus `seedAdmin`.

Done when: browser tab shows Serendib. A new intern can run the stack from `README` alone.

Single source for safaris and destinations

Same parks are typed in `SafariSection.tsx`, `app/safaris/page.tsx`, and `app/safaris/[slug]/page.tsx`. Destinations: `travelTime` is never rendered. Habarana has a slug page but is missing from the homepage grid.

`lib/content/safaris.ts``lib/content/destinations.ts`

Either add Habarana to the grid or delete the orphan page. Render `travelTime` or remove the field.

Done when: changing Minneriya duration in one file updates Home + list + detail.

Buttons must match their labels

- Home card "View Route Details" currently opens WhatsApp 94774639048 (a third number). Link to `/safaris/minneriya` etc.
- Navbar "Book Now" should go to `/booking`. WhatsApp stays on Contact only.
- Create `lib/site.ts` with one phone and one WhatsApp number. Delete the other two from the repo.

Done when: `wa.me/94774639048` is gone. Details buttons open pages, not chat.

Apply Geist and remove dark-mode invert

`layout.tsx` loads Geist variables but never puts them on `<html>`. `globals.css` still has `prefers-color-scheme: dark`, which turns a cream tourism site black at night. Body font is Arial.

Done when: OS dark mode still shows cream/green. Type is Geist, not Arial.

Do not claim Google reviews you do not have

Hero lists "Google reviews". `Testimonials.tsx` uses "International Traveller" with no name or source. Use real quotes with permission, or remove the claim.

Dashboard defects and how to fix them

A1

P1 · Scope

This app is login + dashboard + bookings only

Sidebar items Safari Packages, Destinations, Enquiries, Website Content, Settings are `href="#"`. Stat cards "New Enquiries" and "Safari Packages" are hardcoded 0. Quick Access buttons do nothing. Recent Activity is hardcoded empty even when bookings exist.

- Keep: Dashboard, Bookings, Sign out.
- Delete unfinished nav and fake stats.
- Load latest 5 bookings from GET `/api/bookings`. "View all" → `/bookings`.
- Show confirmed/pending from the real stats payload (the API already returns them).

Done when: a staff user never hits a dead link. A new booking appears on the dashboard.

A2

P1 · Auth placement

Redux belongs only in admin-frontend

Today `StoreProvider` wraps the whole mixed app and calls `POST /api/auth/refresh` on the public homepage. After the split, website-frontend has no `store/` folder at all.

Admin layout: if `sessionChecked && !isAuthenticated` and the route is not `/login`, redirect to login.

Done when: website Network tab never calls `/api/auth/refresh`.

A3

P2 · API client

One fetch helper with a refresh mutex

Dashboard inlines a 401 retry. Bookings has `authenticatedFetch`. Refresh tokens are single-use. Two parallel 401s can rotate twice and log the admin out.

```
admin-frontend/lib/api.ts
```

- Share one in-flight `refreshPromise`.
- 401 → refresh once → retry. Still 401 → clear auth and go to login.
- No raw localhost URLs.

Done when: dashboard and bookings both import the same helper.

Always clear client auth

`logoutAdmin.rejected` only sets `error.admin`, `accessToken`, `isAuthenticated` stay set. If the API is down, Sign out must still wipe local state.

Done when: backend off + Sign out → login page, and refresh does not restore the dashboard.

API defects (customer PII lives here)

POST /api/bookings is public and stores names, emails, phones, travel dates. Without validation and rate limits it is an open mailbox.

B1

P1 · CORS

Allow both frontends

`backend/server.js`

```
origin: (process.env.FRONTEND_URLS || "http://localhost:3000,http://localhost:3001")
  .split(",")
  .map((s) => s.trim())
```

Done when: website :3000 and admin :3001 can both call the API with cookies.

B2

P1 · Rate limit

Throttle login and booking create

```
npm install express-rate-limit helmet --prefix backend
```

- helmet() on all routes.
- express.json({ limit: "16kb" })
- Login: 5 attempts / 15 min / IP → 429
- Create booking: 8 / 15 min / IP → 429

B3

P1 · Validation

Do not trust the browser

new `backend/validators/bookingValidator.js`

- email format; phone 9–15 digits
- experience enum; destination allow-list
- guestCount integer 1–30 (frontend max is 30, API currently has no max)
- travelDate valid and not in the past
- message optional, max 1000

Done when: Postman guestCount: 999 or date 2020-01-01 returns 400. A valid form still returns 201.

Escape regex; fail fast without env

```
const escapeRegex = (value = "") =>
  value.replace(/[*+?^$|{}()|[\]\[\]/g, "\\$&").slice(0, 80);
```

Use that in `getAllBookings`. At startup, exit if `MONGODB_URI`, `JWT_ACCESS_SECRET`, `JWT_REFRESH_SECRET` are missing (min 32 chars). Add `backend/.env.example`. Never commit real passwords.

Error handler, indexes, package main

- Add 4-argument `errorHandler` after the 404 route.
- Indexes on `Booking`: `createdAt`, `{ status, createdAt }`, `email`.
- Set `package.json` main to `server.js`.
- Smoke tests: login fail, create booking, GET `/bookings` without token → 401.

Tick these with your tech lead

Structure

- ☐ Zip flattened (one project root)
- ☐ website-frontend/ exists, no app/admin, no Redux
- ☐ admin-frontend/ exists, no marketing Navbar
- ☐ backend/ unchanged location + validators
- ☐ Website :3000, admin :3001, API :5000
- ☐ CORS allows both origins
- ☐ Root README explains all three

Code quality

- ☐ Images load on website
- ☐ No hardcoded localhost in source
- ☐ Metadata is Serendib, not Create Next App
- ☐ One WhatsApp / phone constant
- ☐ Details CTA → slug page
- ☐ Admin nav only real pages
- ☐ Recent bookings from API
- ☐ Login 429 after 5 failures
- ☐ Invalid booking → 400
- ☐ Missing JWT secret → process exits
- ☐ Website never calls /api/auth/refresh
- ☐ Three smoke tests pass

Do not touch unless asked

Keep	Why
Refresh token rotation + hash	Correct model. Do not rewrite.
Access token in memory (Redux)	Do not move it to localStorage.
Cookie path /api/auth	Limits where the refresh cookie is sent.
Generic login errors	Do not return "email not found".
bcrypt 12 + select:false	Password handling is already correct.

Demo rule: structure split + website images + env URLs + honest admin nav = you may demo locally. Do not put this on the public internet until backend validation and rate limits (B2–B4) are done. Ask questions with the ID (S2, W5, B3).